

CYBER SECURITY & CRIME

Complete Technical Course Handbook & Detailed Syllabus Notes

Teaching Scheme: 3-0-0 (L-T-P)

Coverage: Units I through V (End-to-End)

Focus: Cybercrime, Forensics, & Cyber Law

UNIT I: INTRODUCTION TO CYBER CRIME AND CYBER OFFENSES

1. Introduction: Cybercrime & Information Security

Cybercrime refers to any criminal activity that involves a computer, a networked device, or a network. While most cybercrimes are carried out in order to generate profit for the cybercriminals, some are carried out to damage or disable computers or devices directly, or to spread malware, illegal information, or other materials.

Origins of the Word: The prefix "Cyber" is derived from "Cybernetics," a term coined by Norbert Wiener in 1948 to describe the science of control and communication in animals and machines. The merger of "cyber" and "crime" emerged in the late 1980s and 1990s as malicious activities over early networks (like the ARPANET) became prevalent.

Information Security (InfoSec): The practice of protecting information by mitigating information risks. It is built upon the foundational *CIA Triad*: Confidentiality, Integrity, and Availability. While cybercrime is the offensive threat, Information Security provides the defensive framework.

Who are Cybercriminals?

Cybercriminals are not a monolithic group; they vary widely in motivation, skill, and resources:

- **Script Kiddies:** Unskilled individuals who use scripts or programs developed by others to attack computer systems.
- **Hackers & Crackers:** Technically proficient individuals. "Hackers" often explore systems out of curiosity or for security testing (White Hat), whereas "Crackers" act with malicious intent (Black Hat).
- **Organized Crime Syndicates:** Professional criminal enterprises that operate purely for financial gain (e.g., ransomware gangs).
- **State-Sponsored Actors:** Highly resourced groups backed by national governments, engaging in espionage, intellectual property theft, or sabotage (Advanced Persistent Threats - APTs).
- **Insider Threats:** Disgruntled or compromised employees who misuse their authorized access to harm the organization.

Classifications of Cybercrimes

Cybercrimes are broadly classified into four major categories based on the target of the crime:

Classification	Description & Examples
Against Individuals	Crimes targeting a single person. Examples include Cyberstalking, Harassment, Defamation, Identity Theft, Phishing, and distribution of child pornography.
Against Property	Crimes targeting digital or physical property. Examples include computer vandalism, intellectual property theft, transmitting viruses, and stealing bank details.
Against Organizations	Attacks aimed at disrupting businesses, governments, or institutions. Examples include Distributed Denial of Service (DDoS) attacks, corporate espionage, and ransomware.
Against Society	Broad-scale attacks that threaten national security. Examples include Cyber Terrorism, Cyber Extortion, and attacks on critical national infrastructure (power grids, voting systems).

A Global Perspective & Survival Mantra

Global Perspective: Cybercrime is borderless. An attacker in one country can exploit a server in a second country to steal data from a victim in a third. This creates immense legal and jurisdictional challenges.

Survival Mantra for the Netizens: "Zero Trust." Users must adopt a mindset of continuous skepticism. This involves enabling Multi-Factor Authentication (MFA), keeping software strictly updated, questioning unsolicited communications, and understanding digital footprints.

2. Cyber Offenses: How Criminals Plan the Attacks

Cyber attacks do not happen spontaneously; they follow a systematic lifecycle (often modeled by the Cyber Kill Chain):

1. **Reconnaissance:** Gathering information about the target (social media scanning, network scanning).
2. **Weaponization & Delivery:** Creating a malicious payload (e.g., a macro-enabled Word document) and delivering it via email or a compromised website.
3. **Exploitation & Installation:** Triggering the payload to exploit a vulnerability, resulting in the installation of a backdoor.
4. **Command & Control (C2):** Establishing a connection back to the attacker's server to allow remote manipulation.

Social Engineering & Cyber Stalking

- **Social Engineering:** The psychological manipulation of people into performing actions or divulging confidential information. Rather than hacking the code, attackers "hack" the human. Examples include Pretexting, Baiting, and Quid Pro Quo.
- **Cyber Stalking:** The use of the Internet or other electronic means to stalk or harass an individual, group, or organization. It involves false accusations, monitoring, making threats, and gathering information for harassment.

Cybercafes, Botnets, and Attack Vectors

- **Cybercafe and Cybercrimes:** Public access computers are highly susceptible to keyloggers and malware. Attackers use them to launch attacks anonymously, making tracing the IP address difficult for law enforcement.
- **Botnets (The Fuel for Cybercrime):** A network of private computers infected with malicious software and controlled as a group without the owners' knowledge. They are used to send spam, mine cryptocurrency, or launch massive DDoS attacks.

- **Attack Vector:** The path or means by which a hacker gains access to a computer or network server in order to deliver a payload or malicious outcome. Common vectors include malicious email attachments, unpatched software, and weak credentials.

UNIT II: CYBER CRIME IN MOBILE AND WIRELESS DEVICES

1. Proliferation and Trends in Mobility

The world has rapidly transitioned to a mobile-first computing era. The **Proliferation of Mobile and Wireless Devices** is driven by the widespread adoption of smartphones, tablets, IoT (Internet of Things) devices, and wearable technology.

Trends in Mobility:

- **BYOD (Bring Your Own Device):** Employees using personal devices for corporate work, blurring the line between personal and professional data security.
- **5G Networks:** Offering unprecedented speeds and connectivity, but exponentially increasing the attack surface.
- **Ubiquitous IoT:** Billions of interconnected sensors that often lack basic security features.

2. Security Challenges and Financial Frauds

Mobile computing presents unique challenges not found in traditional desktop environments.

- **Credit Card Frauds in Mobile Era:** The shift to mobile commerce has seen a rise in SMS-phishing (Smishing), malicious point-of-sale (mPOS) malware, and fraudulent rogue apps masquerading as legitimate banking applications to intercept credit card details.
- **Security Challenges Posed by Mobile Devices:**
 - **Physical Vulnerability:** Devices are easily lost or stolen, leading to immediate physical data breaches.
 - **Rogue Wi-Fi Networks:** Mobile devices automatically connecting to unsecured public Wi-Fi networks are vulnerable to Man-in-the-Middle (MitM) attacks.
 - **App Store Malware:** Despite vetting, malicious applications frequently bypass app store security.

3. Technical Vulnerabilities on Mobile Devices

Registry Settings and Authentication

- **Registry Settings for Mobile Devices:** Similar to desktop OS, mobile operating systems (especially Windows Mobile or rooted Android devices) contain low-level configuration settings. Attackers exploit weak registry permissions to alter system behaviors, grant unauthorized app permissions, or disable security protocols.
- **Authentication Service Security:** Mobile devices rely heavily on biometrics (fingerprint, facial recognition), PINs, and token-based authentication (OAuth). Flaws in how these tokens are stored (e.g., plaintext in local storage) or transmitted can allow session hijacking.

Attacks on Mobile/Cell Phones

Attackers target both the hardware and the software of mobile phones:

- **Baseband Attacks:** Exploiting vulnerabilities in the radio processor that communicates with cellular towers (GSM/LTE/5G protocols).
- **Jailbreaking/Rooting Risks:** Users bypassing OS restrictions severely compromise the device's sandbox environment, allowing malware to run with administrative privileges.
- **Malicious Apps & Spyware:** Applications that silently record calls, read SMS messages (often bypassing 2FA codes), and track GPS locations.

Organizational Measures and Security Policies

Security Implications for Organizations: A single compromised mobile device can act as a gateway into a corporate network. Organizations face the risk of data leakage, compliance violations, and unauthorized network access.

Organizational Measures & Policies:

- **Mobile Device Management (MDM):** Software that allows IT administrators to control, encrypt, and enforce policies on smartphones, including remote-wipe capabilities.
- **Containerization:** Isolating corporate data from personal data within the same device.
- **Acceptable Use Policy (AUP):** Defining exactly what employees can and cannot do on devices that access corporate networks.

UNIT III: TOOLS AND METHODS USED IN CYBERCRIME

1. Introduction to Cyber Attack Tools

Cybercriminals leverage a massive arsenal of sophisticated tools and methods to compromise systems, steal data, and maintain anonymity.

Proxy Servers and Anonymizers

Attackers hide their true IP addresses using proxy servers or anonymizing networks. **Proxy Servers** act as intermediaries between a client and the internet. An attacker routes their traffic through multiple proxies (proxy chaining) to obscure their origin. **Anonymizers** (like the Tor Network) use onion routing to encrypt and bounce communications across a distributed network of relays.

2. Phishing and Identity Theft

- **Introduction to Phishing:** A fraudulent attempt to obtain sensitive information (usernames, passwords, credit card details) by disguising as a trustworthy entity in an electronic communication. Sub-types include *Spear Phishing* (highly targeted), *Whaling* (targeting executives), and *Vishing* (voice phishing).
- **Identity Theft (ID Theft):** The deliberate use of someone else's identity to gain a financial advantage or obtain credit and other benefits. Cybercriminals use data harvested from phishing, data breaches, or the dark web to commit ID theft.

3. Malicious Software (Malware) Types

Understanding the distinction between various malicious programs is crucial in cyber security.

Type	Description & Mechanism
Viruses	Malicious code that attaches itself to clean files and infects other clean files. They require human interaction (like running an executable) to spread.
Worms	Standalone malicious programs that replicate themselves to spread to other computers. Unlike viruses, they do not require a host program or human interaction.
Trojan Horses	Malware disguised as legitimate software. Users are tricked into loading and executing Trojans on their systems. They do not self-replicate but often create backdoors.
Backdoors	A hidden method for bypassing normal authentication or encryption in a system. Attackers install backdoors to ensure they have continuous, undetected remote access.
Keyloggers	Hardware or software devices that secretly record every keystroke made on a computer, capturing passwords, emails, and financial data.
Spyware	Software that secretly monitors and gathers information about a user's web browsing, habits, and personal data, transmitting it to a third party.

4. Advanced Exploitation Techniques

- **Password Cracking:** The process of recovering passwords from data that has been stored in or transmitted by a computer system. Methods include:
 - *Dictionary Attacks:* Trying a predefined list of common words.
 - *Brute Force:* Exhaustively attempting every possible character combination.
 - *Rainbow Tables:* Using precomputed hash chains to reverse cryptographic hashes.
- **Steganography:** The practice of concealing a file, message, image, or video within another file. Unlike cryptography, which scrambles the message, steganography hides the *existence* of the message entirely (e.g., altering the Least Significant Bits (LSB) of an image to embed a secret file).
- **DoS and DDoS Attacks:**
 - *Denial of Service (DoS):* Flooding a targeted machine or resource with superfluous requests in an attempt to overload systems and prevent some or all legitimate requests from being fulfilled.
 - *Distributed DoS (DDoS):* Uses a botnet to attack from thousands of different IP addresses simultaneously, making it incredibly difficult to defend against.
- **SQL Injection (SQLi):** A code injection technique used to attack data-driven applications. Malicious SQL statements are inserted into entry fields for execution (e.g., dumping the database contents to the attacker).
- **Buffer Overflow:** An anomaly where a program, while writing data to a buffer, overruns the buffer's boundary and overwrites adjacent memory locations. Attackers exploit this to execute arbitrary shellcode.
- **Attacks on Wireless Networks:** Exploiting vulnerabilities in Wi-Fi protocols. Includes cracking WEP/WPA/WPA2 encryption, setting up "Evil Twin" access points to intercept data, and Deauthentication attacks.

UNIT IV: UNDERSTANDING COMPUTER FORENSICS

1. Introduction to Digital Forensics Science

Computer Forensics (or Digital Forensics) is the application of investigation and analysis techniques to gather and preserve evidence from a particular computing device in a way that is suitable for presentation in a court of law. The goal is to perform a structured investigation while maintaining a documented chain of evidence to find out exactly what happened on a computing device and who was responsible.

The Need for Computer Forensics: With cybercrimes escalating, traditional investigation methods are insufficient. Forensics is needed to trace IP addresses, recover deleted files, decrypt communications, analyze malware, and provide irrefutable digital evidence for prosecution or internal corporate audits.

Cyber Forensics vs. Digital Evidence

- **Cyber Forensics:** The procedural methodology and scientific process used to identify, extract, and analyze digital data.
- **Digital Evidence:** Information stored or transmitted in binary form that may be relied upon in court. This includes hard drives, RAM captures, emails, and server logs. Digital evidence is extremely fragile; merely opening a file can alter its metadata (timestamps), making it inadmissible in court.

2. Forensics Methodologies

The Digital Forensics Life Cycle

1. **Identification:** Recognizing and determining the digital devices and storage media that may contain relevant evidence.
2. **Preservation:** Securing the crime scene and ensuring the data is not altered. This involves creating exact bit-by-bit cryptographic clones (images) of original drives using write-blockers.
3. **Analysis:** Deep examination of the digital clones using specialized tools (like EnCase, FTK, or Autopsy) to recover deleted files, crack passwords, and find hidden data.
4. **Documentation & Presentation:** Creating detailed reports of the findings and presenting them in a manner comprehensible to legal professionals and juries.

Chain of Custody Concept

The **Chain of Custody** is a chronological paper trail that records the sequence of custody, control, transfer, analysis, and disposition of physical or electronic evidence. If the chain of custody is broken or poorly documented, the defense can argue the evidence was tampered with, rendering it inadmissible in court.

Specific Forensics Domains

- **Forensics Analysis of E-Mail:** Involves investigating email header information to trace the origin of phishing or extortion emails. Analysts look at routing paths, IP addresses, Message-IDs, and sender domains to bypass spoofing attempts.
- **Network Forensics:** The capture, recording, and analysis of network events in order to discover the source of security attacks or other problem incidents. Unlike disk forensics, network data is highly volatile and transient.

- **Approaching a Computer Forensics Investigation:** Requires strict adherence to legal frameworks, obtaining necessary warrants, ensuring the use of sterile media, and never working directly on original evidence drives.

3. Forensics and Social Networking Sites

Social networking sites (Facebook, X, LinkedIn) are treasure troves of digital evidence. They provide timelines, geolocations, and communication records.

- **The Security/Privacy Threats:** Users overshare personal information, enabling severe social engineering, cyberstalking, and identity theft.
- **Challenges in Computer Forensics:**
 - *Anti-Forensics:* Attackers intentionally using tools to securely wipe data, alter metadata, or use advanced encryption to thwart investigators.
 - *Cloud and Jurisdiction:* Evidence on social networks is stored on remote servers (often in foreign countries), requiring complex international subpoenas to acquire.
 - *Data Volume:* The sheer massive terabytes of data require immense processing power to filter and analyze.

UNIT V: SECURITY POLICIES AND CYBER LAWS

1. Introduction to Security Policies

Need for an Information Security Policy: A security policy is a formal document that dictates how an organization protects its information assets. It is absolutely essential because technology alone cannot secure a network; humans must understand the rules. Policies dictate Acceptable Use, Password standards, Incident Response protocols, and Data Classification. They align IT security with business objectives and legal compliance.

2. Introduction to Indian Cyber Law

The cornerstone of Indian Cyber Law is the **Information Technology (IT) Act, 2000** (and its subsequent amendments, prominently in 2008). The IT Act provides legal recognition to electronic documents and digital signatures. It defines the legal framework for combating cybercrimes, laying down stringent penalties for hacking (Section 66), publishing obscene information in electronic form (Section 67), and cyber terrorism (Section 66F).

Digital Personal Data Protection (DPDP) Act 2023

The DPDP Act 2023 is a monumental shift in Indian privacy law, replacing outdated frameworks. It governs the processing of digital personal data within India, and outside India if the processing is in connection with offering goods/ services to Indian citizens.

- **Objective and Scope:** To regulate the processing of digital personal data in a manner that recognizes both the right of individuals to protect their personal data and the need to process such data for lawful purposes.
- **Data Fiduciaries & Data Principals:** Organizations collecting data are "Fiduciaries," and the users are "Principals." Fiduciaries must obtain clear, explicit consent before processing.
- **Key Provisions:** Grants users the right to access, correct, and erase their data. Imposes severe financial penalties on organizations that suffer data breaches due to negligence (up to hundreds of crores of rupees).

3. Intellectual Property (IP) Issues

Intellectual Property refers to creations of the mind: inventions, literary and artistic works, and symbols, names, and images used in commerce. The digital era has made IP infringement (like software piracy and digital media copyright infringement) rampant and difficult to control.

Overview of Intellectual Property Related Legislation in India:

IP Type	Definition and Scope in India
Patent	An exclusive right granted for an <i>invention</i> , which is a product or a process that provides a new way of doing something, or offers a new technical solution to a problem. Under the Indian Patents Act, 1970, software <i>per se</i> is not patentable unless it is attached to novel hardware (though interpretations are evolving). Valid generally for 20 years.
Copyright	A legal term used to describe the rights that creators have over their literary and artistic works. In cyber security, source code, website designs, and databases are protected under the Copyright Act, 1957. It prevents unauthorized copying, distribution, or adaptation of the code.
Trademarks	A sign capable of distinguishing the goods or services of one enterprise from those of other enterprises. Governed by the Trade Marks Act, 1999. In the digital realm, this covers domain names (preventing cybersquatting), app names, and brand logos used online.